

1. Objetivo del Pentest

Aurora Market creció rápidamente y pasó de ser una tienda pequeña a una plataforma que almacena información sensible de miles de clientes (datos personales, direcciones, historial de compras). Pese a este crecimiento, la empresa nunca realizó una evaluación formal de seguridad sobre su aplicación web. El disparador concreto de este pentest es que un usuario reportó haber visto información que aparentemente pertenecía a otra cuenta: no hay evidencia confirmada de un ataque, pero el incidente dejó en evidencia que Aurora Market no sabe realmente qué tan expuesta está su plataforma.

Por eso, los objetivos concretos del pentest son:

- Confirmar o descartar si existe una falla real de control de acceso (tipo IDOR) que permita a un usuario acceder a datos de otra cuenta, y determinar su alcance.
- Identificar otras vulnerabilidades relevantes de la aplicación web y evaluar el nivel de exposición que representan para la empresa.
- Proporcionar a Aurora Market información objetiva sobre su nivel de seguridad y una hoja de ruta de remediación priorizada, para que pueda reducir los riesgos identificados.

En definitiva, el valor concreto para Aurora Market es pasar de "una sospecha sin confirmar" a "una decisión de seguridad informada", antes de que un atacante real llegue a ese mismo hallazgo por su cuenta.

2. Alcance

- Dentro del alcance: Aplicación web principal de Aurora Market (módulos de registro, autenticación, perfil de usuario, carrito de compras e historial de pedidos).
- Fuera del alcance: Redes sociales de la empresa, correos personales o corporativos de los empleados, infraestructura de proveedores externos y ataques físicos.

3. Permisos y Condiciones

- Permisos requeridos: Autorización escrita y firmada por la dirección de Aurora Market junto a un acuerdo de confidencialidad (NDA).
- Condiciones propuestas para la ejecución:
 - Realizar las pruebas en horarios de menor tráfico comercial para no afectar la disponibilidad.
 - No ejecutar ataques de denegación de servicio (DoS/DDoS) ni alterar datos reales de los usuarios.

4. Tipo de Pentest

- Tipo elegido: Gray-Box (Caja Gris).
- Justificación: Se cuenta con información parcial de la aplicación (existencia de base de datos y sistema de autenticación, pero sin código fuente), lo que permite simular el comportamiento de un usuario autenticado o un atacante con acceso básico.

5. Planificación

Recopilación de información

La recopilación combina dos tipos de fuentes, siempre dentro del alcance autorizado:

- Fuentes internas: la información que provea directamente Aurora Market, como cuentas de prueba de los usuarios A y B y lo que la empresa ya adelantó sobre su arquitectura (existencia de aplicación web, base de datos, mecanismos de autenticación y distintos tipos de usuario). Las cuentas de prueba se utilizarían como punto de partida para validar los controles de acceso sin afectar usuarios reales.
- Fuentes OSINT (información abierta): datos públicos que no requieren acceso privilegiado, como las tecnologías que utiliza el sitio (por ejemplo con Wappalyzer), los registros DNS y el certificado SSL del dominio de la aplicación web, o una revisión con buscadores para detectar información expuesta accidentalmente (Google dorking). Esto se limita estrictamente a la aplicación web autorizada, sin tocar redes sociales, correos ni infraestructura de terceros, tal como se establezca con el cliente.

El propósito concreto de cada herramienta dentro de este escenario es:

- Nmap: se utilizará como herramienta de reconocimiento para identificar qué puertos y servicios están activos en el servidor que aloja la aplicación web. Sirve para detectar si, además de los puertos web esperados (80/443), hay algo expuesto que no debería estarlo (por ejemplo un panel de administración o un puerto de base de datos accesible desde afuera). Es información de reconocimiento, no de explotación.
- OWASP ZAP: es un scanner semi-automático de aplicaciones web. Se usa para rastrear (crawlear) la aplicación y detectar de forma sistemática vulnerabilidades comunes (headers de seguridad ausentes, cookies mal configuradas, XSS, inyecciones básicas). Da una primera radiografía amplia y rápida, pero no reemplaza el análisis manual dirigido al problema puntual de control de acceso.
- Burp Suite: se usa como proxy para interceptar y modificar manualmente las peticiones. Es clave para el caso de Aurora Market porque el IDOR se prueba cambiando el identificador de un pedido o perfil ajeno estando autenticado como otro usuario, algo que un scanner automático generalmente no detecta por sí solo.

Horarios propuestos

- Reconocimiento pasivo (OSINT y revisión manual de la estructura del sitio): puede realizarse en cualquier horario, ya que no genera carga ni interactúa de forma intrusiva con el servidor.

- Pruebas activas (escaneo con Nmap, crawling con ZAP, pruebas de explotación del IDOR): en ventana nocturna, de 00:00 a 05:00 hora local, de lunes a jueves, evitando fines de semana y períodos de campañas o promociones.

Esta franja es la de menor tráfico real, minimiza el riesgo de degradar la experiencia de clientes reales, facilita distinguir en los logs el tráfico de prueba del tráfico real, y deja las horas de la mañana como ventana de monitoreo antes de que arranque la actividad comercial normal, por si fuera necesario revertir algún cambio.

Metodología a utilizar

OWASP Web Security Testing Guide (WSTG) como marco de referencia para evaluar los controles de seguridad web.

Recursos necesarios

Cuentas de prueba configuradas (roles A y B) y herramientas técnicas de análisis web (Nmap, OWASP ZAP y Burp Suite).

6. Fases del Pentest

Reconocimiento

Se parte de lo que aporte el cliente (información sobre la aplicación y cuentas de prueba) y se complementa con navegación manual de la aplicación: mapear todas las secciones, formularios, parámetros visibles en las URLs —especialmente los identificadores, porque ahí es donde se sospecha el IDOR— y cómo se gestionan las cookies y sesiones.

Los puntos de entrada a identificar son todos los lugares donde la aplicación recibe datos del usuario y responde con datos: login, perfil, carrito, historial de pedidos, y cualquier endpoint detectado al inspeccionar las peticiones con el navegador o con Burp en modo pasivo. Antes de avanzar a la siguiente fase interesa conocer cómo están estructuradas las URLs (¿los IDs son secuenciales y predecibles?), qué tecnología corre por detrás, qué headers de seguridad están presentes y cómo se gestionan las sesiones.

También tiene sentido un análisis de puertos, aplicado únicamente al servidor que aloja la aplicación web autorizada. Con Nmap (`nmap -sV -p-`) se identifican puertos abiertos, servicios y versiones, lo que permite detectar si hay algo expuesto que amplía la superficie de ataque más allá de lo esperado (por ejemplo, un puerto de administración accesible que no debería estarlo).

Análisis de Vulnerabilidades

Se utiliza OWASP ZAP para un escaneo amplio y automatizado (headers, cookies, inyecciones comunes) junto con Burp Suite para el trabajo manual dirigido, en particular para manipular el identificador de un recurso (pedido o perfil) siendo la cuenta A y verificar si se accede a datos de la cuenta B. Lo que se busca obtener es evidencia técnica reproducible de la falla de control de acceso,

detectar si existen otras validaciones de entrada débiles, y confirmar si hay datos sensibles expuestos en las respuestas del servidor. El propósito dentro de la evaluación es convertir la sospecha inicial del cliente en un hallazgo confirmado y documentado, con severidad clasificada (por ejemplo con CVSS), como base para la fase de explotación.

Explotación

Confirmación de la vulnerabilidad intentando acceder a los datos de la cuenta de prueba B estando autenticado como el usuario A.

Post-explotación

Determinación del nivel de acceso alcanzado (por ejemplo, consultar el historial o comprobar qué acciones permitiría realizar la vulnerabilidad) utilizando únicamente cuentas y datos de prueba y evitando modificaciones destructivas.

Informe

Documentación técnica de los hallazgos y redacción de la guía de remediación para los desarrolladores.

7. Investigación

- Metodología elegida: OWASP WSTG.
- Justificación: Es el estándar técnico referente para aplicaciones web y provee casos de prueba específicos para validar la gestión de identidades y controles de acceso (Broken Access Control / IDOR), lo cual atiende directamente el problema reportado por el cliente.